Internship Report

Web Application Security Testing Report

OWASP Juice Shop

Intern: Anubhav Bali

Task: Future Interns Cybersecurity Task 1

Tools Used: Burp Suite, Browser Developer Tools

Tested Application: OWASP Juice Shop (Docker Deployment)

Date of Testing: 20 July 2025

Table of context

Table of context
1. Executive Summary
2. OWASP Top 10 Compliance Checklist
3. Vulnerabilities Identified
    3.1 Cross-Site Scripting (XSS)
    3.2 SQL Injection (SQLi)
    3.3 Insecure Direct Object Reference (IDOR)
    3.4 Sensitive Directory Disclosure via robots.txt
4. Tools Used
5. Recommendations

1. Executive Summary

This report documents the findings from a security assessment performed on the OWASP Juice Shop application. The assessment focused on discovering vulnerabilities listed in the OWASP Top 10, such as SQL Injection (SQLi), Cross-Site Scripting (XSS), and Insecure Direct Object References (IDOR). The goal of this engagement was to identify these weaknesses, demonstrate their exploitation, assess their impact, and provide actionable mitigation recommendations.

2. OWASP Top 10 Compliance Checklist

OWASP Category	Relevant to Finding in Report	Compliance Status
A01: Broken Access Control	IDOR on /rest/basket/{id}	Not Compliant
A02: Cryptographic Failures	No SSL/TLS issue observed (assumed default local app)	N/A (Test Local)
A03: Injection	SQL Injection in Login (/login)	Not Compliant
A04: Insecure Design	No business logic flaws detected	Compliant
A05: Security Misconfiguration	Directory Listing via /robots.txt and /ftp/	Not Compliant
A06: Vulnerable and Outdated Components	No vulnerable libraries detected during scan	Compliant
A07: Identification and Authentication Failures	Login bypass via SQLi	Not Compliant
A08: Software and Data Integrity Failures	No unsigned code or CI/CD tampering observed	Compliant
A09: Security Logging and Monitoring Failures	No critical logging issues surfaced in this context	Compliant
A10: Server-Side Request Forgery (SSRF)	No SSRF-related endpoints tested	Compliant

3. Vulnerabilities Identified

3.1 Cross-Site Scripting (XSS)

Overview:

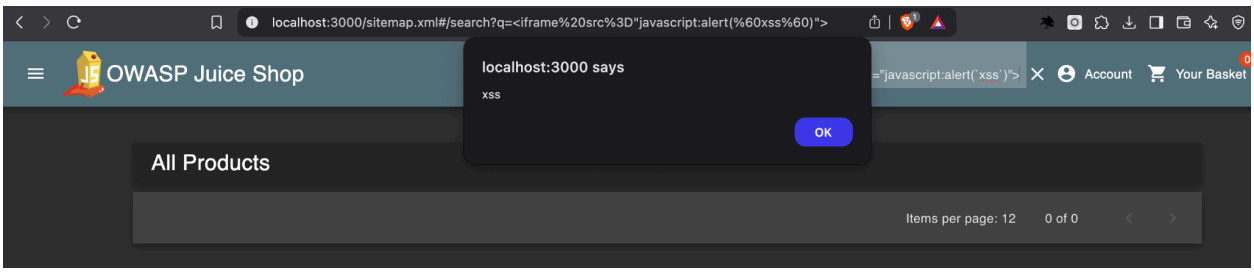
Vulnerability	Cross Site Scripting
Description	**Cross-Site Scripting (XSS) attacks are a type of injection, in which malicious scripts are injected into otherwise benign and trusted websites. XSS attacks occur when an attacker uses a web application to send malicious code, generally in the form of a browser side script, to a different end user. Flaws that allow these attacks to succeed are**

Vulnerability	Cross Site Scripting
	quite widespread and occur anywhere a web application uses input from a user within the output it generates without validating or encoding it.
Cve/Cwe	CWE-79
Rating	High
CVSS Rating	CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N
Endpoint	/search

Payload: `<iframe src="javascript:alert(`xss`)">`

Reproduction Steps:

The vulnerability was discovered in the search functionality of the application. By entering the given payload into the search field, the browser executed JavaScript, resulting in a visible alert popup. This indicates the application fails to properly sanitise user input before rendering it on the page.



Impact:

This DOM-based XSS vulnerability could allow attackers to execute arbitrary scripts in the context of a user's session, leading to session hijacking, defacement, or redirection to malicious websites.

Mitigation:

Sanitise and encode all user inputs before rendering. Implement a strict Content Security Policy (CSP) to mitigate the impact of potential XSS:

Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none';

3.2 SQL Injection (SQLi)

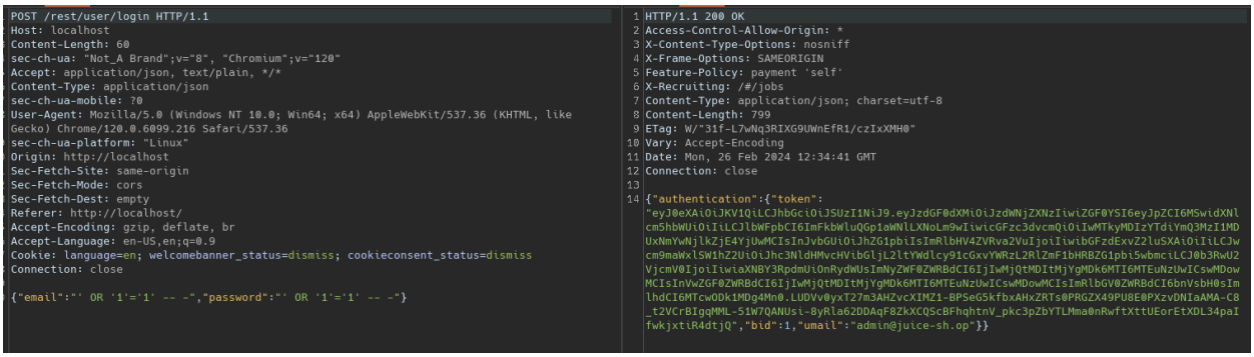
Overview:

Vulnerability	SQL Injection
Description	**The product constructs all or part of an SQL command using externally influenced input from an upstream component, but it does not neutralize or incorrectly neutralizes special elements that could modify the intended SQL command when it is sent to a downstream component.**
Cve/Cwe	**CWE-89**
Rating	**High**
CVSS Rating	**CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N**
Endpoint	**/login**

Payload: `admin' OR '1' = '1' -- -`

Reproduction Steps:

This vulnerability was identified in the login form. The payload was entered in the email/username field, while the password field was left blank. The system authenticated the user and granted access, bypassing standard credential checks.



Impact:

Successful exploitation of this vulnerability can lead to unauthorized access to user or administrator accounts, data leakage, and full application compromise.

Mitigation:

Use parameterized queries (prepared statements) to prevent injection of untrusted input into SQL statements. Avoid dynamic query construction using user-supplied data.

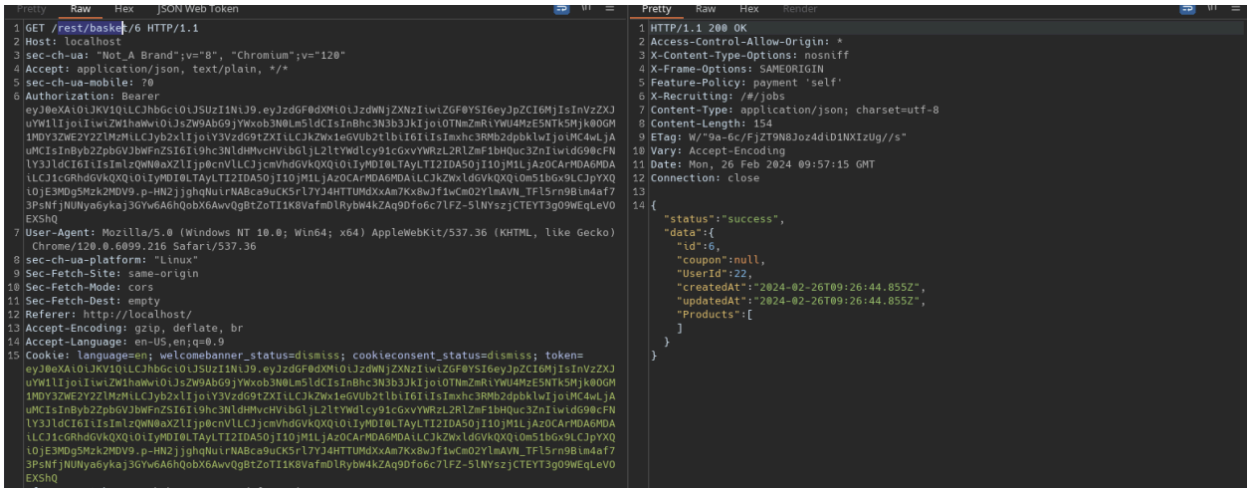
3.3 Insecure Direct Object Reference (IDOR)

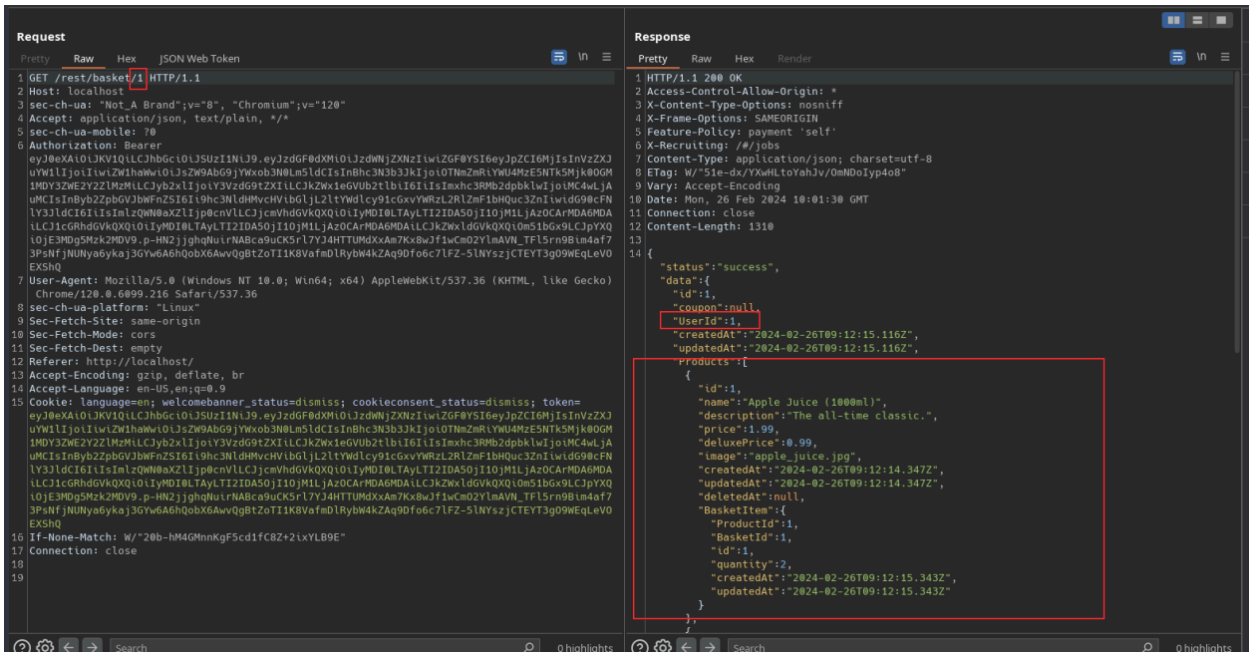
Overview:

Vulnerability	**Insecure Direct Object Reference**
Description	**The system's authorization functionality does not prevent one user from gaining access to another user's data or record by modifying the key value identifying the data.**
Cve/Cwe	**CWE-639**
Rating	**High**
CVSS Rating	**CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N**
Endpoint	**/rest/basket/{id}**

Reproduction Steps:

The view basket endpoint is vulnerable to insecure direct object reference it is possible to view other accounts baskets through manipulation of the ID that is in the url, a request of me viewing my basket:





When the basket ID was modified from 6 to another value such as 1, the application disclosed the contents of another user's basket, confirming the presence of an IDOR vulnerability.

Impact:

This IDOR vulnerability allows unauthorized users to access or manipulate data they should not have permissions for, posing a risk to confidentiality and integrity.

Mitigation:

Implement object-level access control checks on the server side. Ensure that every request is verified against the authenticated user's permissions and context.

3.4 Sensitive Directory Disclosure via robots.txt

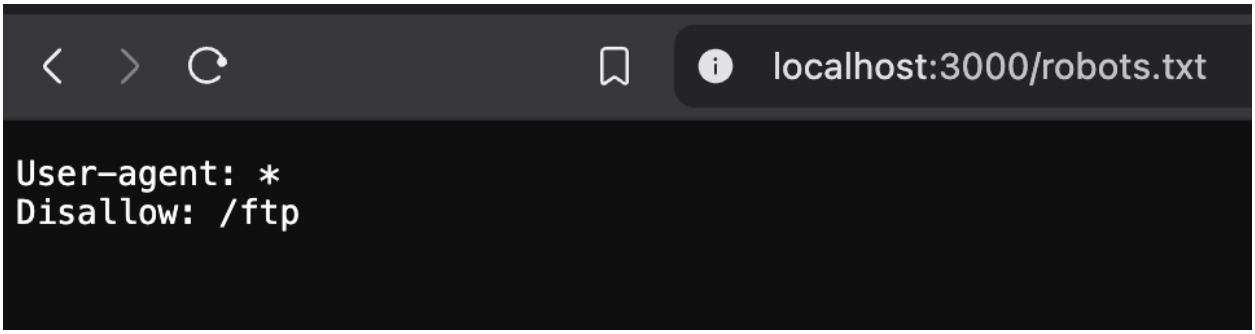
Overview:

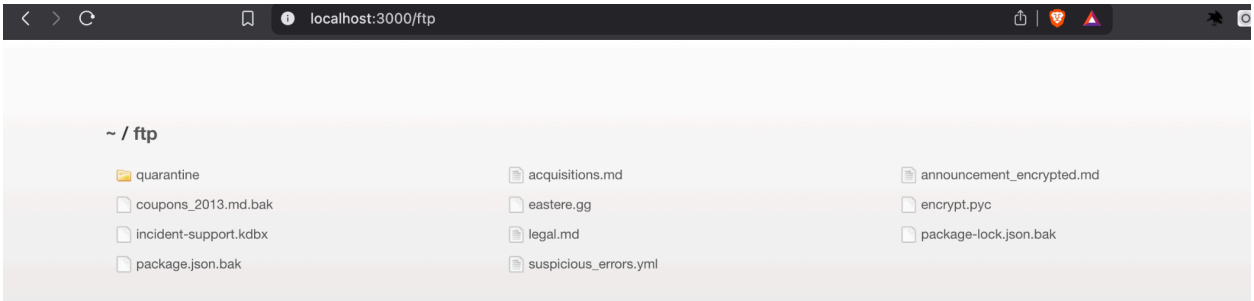
Vulnerability	**Information Disclosure**
Description	**The product exposes sensitive information to an actor that is not explicitly authorized to have access to that information.**
Cve/Cwe	**CWE-220**
Rating	**High**
CVSS Rating	**CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N**

Vulnerability	Information Disclosure
Endpoint	/robots.txt

Reproduction Steps:

Navigate to http://localhost/robots.txt you will then find a link to the ftp public access folder of the website





Impact:

Sensitive or internal directories revealed through **robots.txt** entries may contain configuration files, user data, backups, credentials, or logs. Attackers often scrape **robots.txt** first to locate such hidden resources. If file browsing is enabled, this could lead to unauthorized access, data leakage, or further exploitation.

Mitigation:

Disallow the access to the ftp folder through .htaccess or other methods

4. Tools Used

The assessment was conducted using Burp Suite for request interception and manipulation, OWASP ZAP for scanning, SQLMap for automated injection detection, and browser Developer Tools for DOM testing. The testing methodology followed standard penetration testing phases: reconnaissance, scanning, exploitation, and reporting, with a focus on the OWASP Top 10 and relevant Juice Shop challenge patterns.

5. Recommendations

- Remediate all OWASP Top 10 vulnerabilities identified in this report.
- Deploy a Web Application Firewall (WAF) to detect and block common exploits.
- Conduct periodic automated and manual security assessments.
- Integrate security testing into CI/CD pipeline.
- Enforce input validation and output encoding on all user input.
- Review and restrict access control for all sensitive resources and API endpoints.